

W21D1_ESERCIZIO INTELLIGENZA ARTIFICIALE E CYBERSECURITY

Crea un prompt che aiuti la tua organizzazione a implementare delle misure di sicurezza contro il ransomware partendo da una simulazione di attacco.

PROMPT UTILIZZATO: dobbiamo aiutare la nostra organizzazione ad implementare misure di sicurezza contro un ransomware, puoi simulare uno scenario di attacco reale ?

Per difendersi efficacemente, bisogna pensare come l'attaccante. Un attacco ransomware moderno non è un evento isolato, ma una progressione metodica chiamata **Ransomware-as-a-Service (RaaS)**.

Ecco la simulazione di uno scenario realistico, suddiviso nelle fasi critiche della "Kill Chain".

Simulazione di un Attacco Ransomware

Fase 1: Accesso Iniziale (Il Cavallo di Troia)

L'attaccante non "sfonda" la porta, solitamente usa una chiave rubata o inganna qualcuno per farsi aprire.

- **Scenario:** Un dipendente del reparto amministrativo riceve un'e-mail di **phishing** molto mirata che sembra provenire da un fornitore noto, sollecitando il controllo di una fattura scaduta in formato .zip o tramite un link a un finto portale Microsoft 365.
- **Vulnerabilità:** Mancanza di MFA (Autenticazione a due fattori) o scarsa formazione del personale.

Fase 2: Esplorazione e Movimento Laterale

Una volta dentro un singolo PC, l'attaccante non cripta subito i dati. Sarebbe troppo rumoroso. Inizia a "guardarsi intorno".

- **Azione:** Utilizza strumenti come *Mimikatz* per estrarre credenziali dalla memoria del PC compromesso. Cerca di scalare i privilegi per diventare **Domain Admin**.
- **Obiettivo:** Identificare i server critici, i database e, soprattutto, i **server di backup**.

Fase 3: Esfiltrazione dei Dati (La Doppia Estorsione)

Prima del blocco, i dati vengono rubati.

- **Azione:** L'attaccante copia i dati sensibili (contratti, dati personali, segreti industriali) su un server esterno controllato da lui.
- **Perché:** Se l'azienda riesce a ripristinare i backup senza pagare, l'attaccante minaccia di pubblicare i dati rubati sul "Dark Web".

Fase 4: Esecuzione e Criptazione

È il momento del "botto". Spesso accade di venerdì sera o durante i festivi per ritardare la risposta del team IT.

- **Azione:** Il ransomware viene distribuito su tutta la rete tramite script automatizzati. I file diventano illeggibili e le estensioni cambiano (es. .locked o .crypted).
- **Risultato:** Appare una nota di riscatto (file .txt o .html) su ogni desktop con le istruzioni per il pagamento in Bitcoin.

Misure di Prevenzione Suggerite

Per evitare che questo scenario diventi realtà, ecco una tabella di marcia sulle priorità:

Priorità	Misura di Sicurezza	Descrizione
Alta	Multi-Factor Authentication (MFA)	Obbligatoria per ogni accesso esterno (VPN, Email, Cloud).
Alta	Backup Immutabili (Regola 3-2-1-1)	Almeno una copia dei dati deve essere offline o non modificabile.
Media	Endpoint Detection & Response (EDR)	Software che rileva comportamenti anomali (es. un PC che cripta 1000 file al minuto).
Media	Segmentazione della Rete	Impedire che un PC dell'amministrazione possa comunicare direttamente con i server di produzione.

ESERCIZIO FACOLTATIVO : riassunto del report 2025-dbir-data-breach-investigation

PROMPT UTILIZZATO: mi faresti un riassunto di questo report?

Il **2025 Data Breach Investigations Report (DBIR)** di Verizon analizza un numero record di **22.052 incidenti di sicurezza**, di cui ben **12.195 sono violazioni di dati (breach) confermate** provenienti da 139 paesi.

Ecco i punti chiave emersi dal rapporto:

1. Il Ruolo Critico delle Terze Parti

Il tema centrale di quest'anno è l'impatto delle relazioni con terze parti nella genesi delle violazioni. Negli ultimi due o tre anni, i problemi legati a fornitori di software e partner sono passati da incidenti occasionali a un problema diffuso e insidioso che può devastare le imprese.

2. Vettori di Accesso Principali

- **Abuso di Credenziali:** Rimane il vettore più comune, presente nel **22%** delle violazioni (o 31% secondo la nuova formulazione del report).
- **Sfruttamento di Vulnerabilità:** È cresciuto del **34%** rispetto all'anno scorso, raggiungendo il **20%** dei casi. Questo aumento è stato alimentato in particolare da exploit zero-day su dispositivi edge e VPN.
- **Phishing:** Si attesta al **16%** (o 14% a seconda della metrica), scendendo al terzo posto tra i vettori di accesso iniziale.

3. Ransomware e Estorsione

- Il ransomware rimane una minaccia onnipresente e la sua incidenza come percentuale di violazioni è **cresciuta ulteriormente**.
- Un dato interessante è il **calo dell'importo mediano del riscatto pagato**, nonostante l'aumento della frequenza degli attacchi.
- Il ransomware è spesso scoperto tramite la "divulgazione dell'attore" (es. post sul Dark Web), che rappresenta il **96%** dei metodi di scoperta per questo tipo di attacco.

4. L'Elemento Umano

- La stragrande maggioranza delle violazioni coinvolge ancora l'elemento umano, sia attraverso errori non intenzionali (come l'invio di dati al destinatario

sbagliato) che tramite interazioni attive (cliccare su un'e-mail di phishing o rispondere a una chiamata truffaldina).

5. Analisi per Settore

- **Sanità (Healthcare):** Le intrusioni di sistema (incluso il ransomware) hanno superato gli errori vari come causa principale delle violazioni.
- **Manifatturiero:** La presenza di malware è salita al **66%**, con il ransomware che domina il panorama in questo settore.
- **PMI vs Grandi Aziende:** Si osserva una convergenza del panorama delle minacce indipendentemente dalle dimensioni dell'organizzazione, poiché entrambe si affidano a strumenti simili e subiscono attacchi basati sull'estorsione.

6. Sfide Tecniche Emergenti

- **Infostealer e BYOD:** Il report evidenzia il problema dei malware infostealer, notando che il **46%** dei sistemi compromessi con log di accesso aziendali erano dispositivi non gestiti (BYOD), sottolineando i rischi di non avere politiche di controllo rigorose su tali dispositivi.

SECONDO PROMPT UTILIZZATO: dal report evidenzia le informazioni che riguardano social engineering e phishing

Il report **2025 Data Breach Investigations Report (DBIR)** dedica un'ampia sezione all'analisi del **Social Engineering** e del **Phishing**, identificandoli come vettori critici che sfruttano l'elemento umano per ottenere l'accesso iniziale alle reti aziendali.

Ecco i punti principali emersi dal report:

1. Statistiche e Tendenze Generali

- **Vettore di Accesso Iniziale:** Il phishing si conferma come uno dei tre principali vettori di accesso iniziale per le violazioni (escludendo errori e abusi di privilegi), rappresentando il **16%** dei casi analizzati.
- **Prevalenza del Pattern:** Il Social Engineering è costantemente tra i primi tre pattern di attacco dal 2019. Quest'anno, in alcuni settori come la Pubblica Amministrazione, si è conteso il terzo posto con i Basic Web Application Attacks.

- **Motivazioni:** Le violazioni legate al Social Engineering sono guidate principalmente da scopi **finanziari (55%)** e di **spionaggio (52%)**.
- **Dati Compromessi:** I dati più comunemente esfiltrati tramite queste tecniche includono dati interni (**68%**), segreti aziendali (**53%**) e credenziali.

2. Evoluzione delle Tecniche

- **Oltre il Phishing Tradizionale:** Sebbene il phishing rimanga la varietà d'azione preferita, il report segnala l'emergere del **Pretexting** e del **Prompt Bombing**.
- **Prompt Bombing:** Questa tecnica consiste nell'inviare un numero elevato di richieste di autenticazione agli utenti sperando che questi confermino l'accesso per "sfinimento". Ha avuto successo in più di 20 casi nel set di dati analizzato.
- **Tempo di Preparazione:** Gli attaccanti dedicano sempre più tempo a costruire una familiarità con le vittime per rendere l'inganno più credibile.
- **Impatto dell'IA:** Il report indica che la percentuale di email malevole assistite dall'Intelligenza Artificiale è **raddoppiata** negli ultimi due anni (passando dal 5% a circa il 10%), utilizzata soprattutto per migliorare la grammatica e la traduzione delle esche.

3. L'Elemento Umano e la Formazione

- **Coinvolgimento Umano:** L'elemento umano è presente in circa il **60%** delle violazioni totali.
- **Efficacia dei Test di Phishing:** Le simulazioni aziendali mostrano che, nonostante la formazione, esiste un "zoccolo duro" (mediana dell'1,5% dei dipendenti) che continua a cliccare sui link malevoli indipendentemente dalle sessioni di training.
- **Reporting:** Un dato positivo è che la formazione continua aumenta il tasso di **segnalazione** delle email sospette da parte dei dipendenti, anche se questi hanno accidentalmente cliccato sul link.

4. Misure di Controllo Consigliate dal Report

Il report suggerisce diverse contromisure basate sui controlli CIS (Center for Internet Security):

- **Sicurezza degli Account:** Implementare obbligatoriamente l'**MFA (Multifactor Authentication)** per tutte le applicazioni esposte esternamente e per gli accessi remoti.
- **Protezione Email e Browser:** Utilizzare servizi di filtraggio DNS.

- **Formazione:** Implementare programmi di sensibilizzazione e formazione sulle competenze di sicurezza (Security Awareness Training).
- **Password:** Abbandonare i requisiti di complessità obsoleti a favore di **passphrase** lunghe e proteggere le credenziali anche sui sistemi interni, poiché l'MFA sulla VPN non protegge necessariamente i sistemi amministrativi una volta che l'attaccante è all'interno.